

MBS CRM — Project Audit Report

Report Date: July 12, 2026 | Commit: c422341

1. Republish Status

& The live deployment is behind commit c422341.

The production deployment is running (confirmed via deployment logs, request IDs 1297–1386+, most recent log ~2026-07-12 19:xx UTC). However, no republish was triggered after the governance formalization commit (c422341 — "Enterprise data governance + compliance formalization"). The last successful publish predates that commit.

The production build therefore does NOT contain:

- The pii_access_log table instrumentation
- The /governance admin page
- The RTBF / retention purge endpoints
- The consent visibility panel and SMS consent guard
- The drip consent skip logging

Action required (when ready): Republish from commit c422341. The DB schema changes (pii_access_log, retention_months) were already pushed to the shared Postgres database and are live — only the API server and frontend code are behind.

2. External Monitoring Recommendation

2a. Error Tracking — Sentry

Recommendation: Yes, Sentry. Free tier is sufficient.

Sentry has first-class Express and React/Vite SDKs and works without any infrastructure changes on a Replit Reserved VM.

Side	Package	Env Var
API Server (Express 5)	@sentry/node	SENTRY_DSN
Web Frontend (Vite)	@sentry/react	VITE_SENTRY_DSN

Implementation: `Sentry.init({ dsn: process.env.SENTRY_DSN });`
`Sentry.withSentry(App)` on the frontend. Express 5 `asyncHandler` middleware.

Replit constraint: Do NOT use `@sentry/profiling-node` — requires native binaries that may not compile on NixOS.

Cost: Free tier (5,000 errors/month, 10k transactions/month) is sufficient. Paid starts at ~\$26/month.

Today without it: Errors appear only in the Replit workflow console (ephemeral, no alerting). A production crash is silent until someone notices the app is broken.

2b. Uptime Monitoring — Better Stack

Recommendation: Better Stack (free tier sufficient). Cost is deep.

Setting	Value
URL	https://<your-replit-domain>/api/health/deep
Check interval	3 minutes
Alert channel	Email (primary) + SMS optional
Expected status	200
Timeout	10 seconds

Better Stack free tier: 10 monitors at 3-minute intervals with email alerts. UptimeRobot (free, 5-minute intervals). Better Stack preferred because it also does log ingestion and with error spikes.

Today without it: If the deployment crashes or DB connection fails, the team finds out when a rep can't log in — no proactive notification exists.

3. Scheduled Off-Site Backup Recommendation

3a. Schedule and Destination

Recommendation: External S3-compatible bucket (Backblaze B2), daily at 02:00 UTC.

Option	Off-site?	Cost	Verdict
Replit Object Storage	No	~\$0.03/GB	REJECT — same infrastructure
External S3 (Backblaze B2)	Yes	~\$0.006/GB	RECOMMENDED
Email / Google Drive	Yes	Free	Not suitable at scale

Replit Object Storage is not sufficiently off-site and the backup. Backblaze B2 is S3-compatible.

3b. Implementation Requirements

- New job: A scheduled cron (node-cron) to export and streaming the result to B2 using `awscli`.
- New env vars: `B2_BUCKET_NAME`, `B2_KEY_ID`, `B2_KEY`.
- Storage cost: Export at current scale is ~\$0.03/GB.
- Retention: 30 daily backups, then weekly full backup.

3c. SSN and Raw Credit Payload Exclusion

- **Confirmed — both are excluded from export**
 - SSNs: `ownerSsnEncrypted` is exported, but `ownerSsn` is NOT decrypted for this export."
 - Raw credit payloads: The `creditPulls` column in the response payload column is not included.
- A scheduled backup calling the same endpoint.

4. Dependency

Audit Results

pnpm audit as of commit c422341:

0 Critical 4 High 8 Moderate

HIGH Vulnerabilities —
all attributable to xlsx
(SheetJS community
edition)

Package	Severity	Issue	Why Not Fixed
xlsx	HIGH	Prototype pollution	No safe npm upgrade — fix is in commercial...
xlsx	HIGH	ReDoS	Patched versions listed as <0.0.0 in npm advisory

Recommended action: Replace xlsx with exceljs (actively maintained, same API surface, no known HIGH vulns). This is a deliberate deferred item — see section 5.
The 8 moderate and 2 low findings are transitive dep mobile artifact — LOW severity, patched in 7.29.6) w

5. Items Flagged But Not Done

Item	Batch	Status	Reason
Replace xlsx with exceljs	Security/Deps	Deferred	Admin-only endpoint, no remote exploit...
Sentry wiring	Observability	Report-only	Batch specified recommendation only, no...
Uptime monitor setup	Observability	Report-only	Same as above.
Scheduled off-site backup	Security/Dur.	Report-only	On-demand export implemented;...
ENCRYPTION_KEY + 5 Twilio...	Security	Pending user	Code paths exist and are guarded;...
@babel/core upgrade (Expo)	Dep audit	Deferred	Requires Expo SDK upgrade coordinatio...

All deliverables specified across the three e governance) were fully implemented. The ite pending user-provided secrets, or identified